Shear Heaven Pet Care - Retest Round 2

Retest of the 37 defects that were not fixed in round 1 (build index-D508zd3N), executed on the new front-end build **index-C63CMm-c** on 11 Nov 2026. Every result was observed in this run; nothing is marked Fixed without re-execution. The 27 defects verified fixed in round 1 and SEC-01 (closed by design) were not part of this round.

Result (round 2)	Defects
Fixed	3
Not reproduced (new data)	1
Partially fixed	10
Still reproduces	21
Blocked	1
Inconclusive	1
Total retested	**37**

Bug	Round 1	Round 2
API-03	Still reproduces	Partially fixed
DB-01	Partially fixed	Fixed
DB-06	Still reproduces	Partially fixed
DB-07	Still reproduces	Fixed
DB-08	Still reproduces	Partially fixed
FUN-14	Still reproduces	Fixed
FUN-21	Blocked	Partially fixed
UI-05	Not re-tested	Still reproduces
UI-13	Still reproduces	Partially fixed

Severity	Still open
Critical	0
High	0
Medium	13
Low	18
Total	**31**

Summary

9 of 37 defects changed status on this build: newly **fixed** - DB-01 (revenue figures now reconcile across dashboard, report and receipts; the last open High), DB-07 (groomer schedule shows package name) and FUN-14 (free-text pet weight rejected); **improved to partially fixed** - API-03, DB-06, DB-08, FUN-21, UI-13; UI-05, which could not be checked in round 1, was retested and still reproduces. Nothing regressed. **31** defects remain open (0 Critical, 0 High, 13 Medium, 18 Low). FUN-07 stays blocked because QA-store bookings still get an empty service plan, and the load test (PERF-01) stays inconclusive because the test browser caps throughput at ~3 requests/s. Recommendation: no blocking defects remain; schedule SEC-08, SEC-09, SEC-10/11, DB-03, UI-02, FUN-10/11/18 and the UI-text items for the next build, and run load testing with k6/JMeter from a server.

Defect-by-defect results

Bug ID	Sev	Role	Title	Round 1	Round 2	Observed on build index-C63CMm-c (evidence)
SEC-08	Medium	Customer	Existing sessions stay valid after a password reset	Still reproduces	**Still reproduces**	Reset via OTP (new password Qa@Cust2029) → 200; old password 401, new 200; access token issued before the reset still 200 "Profile retrieved successfully"
SEC-09	Medium	Customer	Photo upload trusts the declared type; HTML saved as .png and served without nosniff	Still reproduces	**Still reproduces**	GET /uploads/pets/pet-1794384464556-8818422.png → 200, Content-Type image/png, body "<html><script>alert(1)</script></html>" (HTML still stored and served; nosniff not visible to the browser)
SEC-10	Medium	All	Missing HTTP security headers (CSP, HSTS, X-Frame-Options, nosniff, Referrer-Policy)	Still reproduces	**Still reproduces**	GET https://pcmdev.shearheavenpetspa.com/ (same-origin) → no CSP, HSTS, X-Frame-Options, X-Content-Type-Options or Referrer-Policy headers
SEC-11	Medium	All	Swagger API docs publicly accessible on the API host	Still reproduces	**Still reproduces**	GET https://api.shearheavenpetspa.com/api-docs/ → 200 Swagger UI HTML
SEC-12	Low	Customer	Forgot-password timing reveals whether an account exists	Still reproduces	**Still reproduces**	forgot-password: registered email 2,041 / 1,644 / 1,435 ms vs unknown 599 / 587 / 908 ms (same 200 message)
SEC-13	Low	All	24-hour access tokens and 7-day refresh tokens stored in localStorage	Still reproduces	**Still reproduces**	Customer JWT exp – iat = 86,400 s (24 h); tokens in localStorage (sh_access_token, sh_refresh_token)
SEC-14	Low	All	Dev front end calls the API host api.shearheavenpetspa.com	Still reproduces	**Still reproduces**	Bundle index-C63CMm-c.js contains https://api.shearheavenpetspa.com as the only API base
FUN-07	Medium	Groomer	Setting a service line to 100% the first time leaves it 'in progress', blocking checkout	Blocked	**Blocked**	QA-store bookings #236, #243, #246, #248 still return servicePlan {includesBath:false, includesGrooming:false, tasks:[]} and serviceProgress []; groomer modal shows no service lines, so the 100% step cannot be run
FUN-10	Medium	Admin	Pet size tiers accept overlapping ranges, min > max and duplicate keys; default tiers leave weight gaps	Still reproduces	**Still reproduces**	PUT /api/common/pet-size-prices (QAA-001): Medium 5–30 overlapping Small 1–10 → 200 'Store pet size prices saved'; Small 20–10 (min > max) → 200; two tiers with key 'small' → 200. Original tiers restored afterwards
FUN-11	Medium	Admin	Store content is never shown on the customer site, and invalid metadata JSON is accepted	Still reproduces	**Still reproduces**	POST /api/common/store-content (QAA-001, key faq) with metadata '{not json' → 201, stored as the raw string (test item id 5 deleted afterwards); public routes /api/public/store-content[/contact-info] → 404 and the customer site never requests store content
FUN-13	Medium	Customer	Stores have no time zone; past same-day slots are offered and bookable	Partially fixed	**Partially fixed**	At 13:14 UTC (08:14 New York, 18:44 IST) availability for today still lists 09:00–12:00 as "available", but POST 10:00 → 400 "Cannot book a time slot that has already passed" (17:00 accepted, test booking #252 then declined by the groomer). Store still has no time-zone field, so "past" is judged in UTC, not store time
FUN-14	Medium	Customer	Pet weight accepts any text and the booking is silently priced as Medium	Still reproduces	**Fixed**	POST /api/pets with weight 'Gigantic' → 400 'Select a weight band from your store list.'; Add pet form offers only the store's bands
FUN-18	Low	Admin	Store ID accepts special characters (quotes, --)	Still reproduces	**Still reproduces**	POST /api/common/stores with storeId "QRS-002'--" → 201 'Store created successfully' (id 45); test store deleted afterwards (200)
FUN-20	Low	Admin	Validation gaps and truncated error text ('value failed custom validation because')	Partially fixed	**Partially fixed**	Admin edit customer name 'QA Customer (admin edit)' → 400 'name failed custom validation because' (message still truncated, no reason given); name unchanged
FUN-21	Low	Customer	Receipt has no line items when a visit was completed without service-line tracking	Blocked	**Partially fixed**	Receipt #245 (and #236) now has 1 line "Appointment $61.50" (was []), but not itemised (QA Full Groom + QA Teeth Brushing add-on); taxRatePercent still 8.88 vs store rate 8.875
FUN-22	Low	Customer	'Change password' sends signed-in users to the forgot-password flow; reset email uses the verification template	Partially fixed	**Partially fixed**	Profile > Change password still redirects to /forgot-password (email pre-filled qa.cust1101@mailinator.com; no current/new-password form); reset email received at 18:3x IST still titled "Verify Your Email … complete your email verification"
DB-01	High	Admin	Revenue figures disagree with each other and with receipts (coupon not deducted; unfinished visit counted)	Partially fixed	**Fixed**	11 Nov: completed #231 ($55), #236 ($67–$5.50), #245 ($67–$5.50) = $178 net. Dashboard revenue $178, byStatus completed 3; Report: completedCheckouts 3, actualSalesTotal $178, tax $15.80, tips $20, gross $213.80 = sum of finalTotals ($71.96+$64.88+$76.96)

Bug ID	Sev	Role	Title	Round 1	Round 2	Observed on build index-C63CMm-c (evidence)
DB-02	High	Customer	Stored price of package booking #234 changed from $102 to $157 after creation	Not reproduced (new data)	**Not reproduced (new data)**	#241 and #248 still $102 / $111.05 as created; legacy #234 still $157 / $170.93 (not corrected)
DB-03	Medium	Groomer	Groomer forecast counts and amounts inconsistent	Still reproduces	**Still reproduces**	GET /api/common/groomer/forecast 11 Nov (QA Alpha): financialSummary completedCount 1, completedSalesAmount $233, forecastServiceAmount $122; same response groomerSummaries completedCount 3, completedSales $178, forecastRemaining $177
DB-06	Medium	Customer	Package bookings lose their package name; UI titles them by the first service	Still reproduces	**Partially fixed**	My bookings cards now show "Package: QA Spa Package" (#234, #241, #242, #248) and API packageName is set; card title still "QA Full Groom" (first service) instead of the package name
DB-07	Medium	Groomer	Groomer schedule returns packageName null for package bookings	Still reproduces	**Fixed**	GET /api/common/groomer/schedule (QA Alpha) → #241 and #248 packageName "QA Spa Package"
DB-08	Medium	Admin	Admin bookings list returns packageName null and no add-ons for package bookings	Still reproduces	**Partially fixed**	Admin GET /api/common/bookings: #234/#241/#248 now packageName "QA Spa Package" (was null), but addOns [] while addOnIds [312] (QA Teeth Brushing) - add-on details still missing
API-03	Low	All	Role-mismatch and unknown routes return 401 instead of 403/404	Still reproduces	**Partially fixed**	Groomer token on /api/common/stores → 403 (was 401); unknown route PUT /api/common/nope-route → 404 (was 401); customer token on admin route still 401 "Invalid or expired access token"
API-04	Low	Customer	Impossible date reported as 'past date'; cancel message says 'cancelled' when only requested	Partially fixed	**Partially fixed**	POST /api/bookings bookingDate 2026-02-30 still → 400 "Cannot book appointments on past dates" (should say invalid date). The cancel-message part was fixed in round 1 and not changed here
UI-02	Medium	Customer	Booking wizard offers empty packages that then fail at booking	Still reproduces	**Still reproduces**	Booking wizard step 2 lists 'QA Pkg Bad / QA Pkg CrossStore / QA Pkg Deleted — $50.00 · 60 min'; home Packages section lists them too
UI-05	Medium	Admin	Package form shows a stale service list until reload	Not re-tested	**Still reproduces**	Renamed QA Full Groom → 'QA Full Groom R' in Service master (PUT 200); Package master opened without reload still listed 'QA Full Groom #309'; after reload 'QA Full Groom R #309'. Name restored afterwards
UI-06	Low	Customer	Upcoming sorted latest-first; cards show pre-tax price	Still reproduces	**Still reproduces**	My bookings > Upcoming still latest-first (#248 4 Dec at top, #235 11 Nov at bottom); cards show $55.00 / $102.00 (pre-tax) instead of $59.88 / $111.05
UI-07	Low	Customer	Cancel dialog buttons read 'Cancel' and 'Cancel appointment'	Still reproduces	**Still reproduces**	Cancel dialog buttons: 'Close', 'Cancel', 'Cancel appointment'
UI-08	Low	Customer	Coupon dropdown shows identical labels	Still reproduces	**Still reproduces**	Review step coupon dropdown: '10% on services · 10% on services' ×3 and '$5000.00 on services · $5000.00 on services' - no codes, identical labels
UI-09	Low	Customer	Newsletter email field has no accessible label	Still reproduces	**Still reproduces**	Home newsletter input (placeholder "Enter your email address...") has no id/label, no aria-label, not wrapped in <label>
UI-11	Low	Groomer	'Early check-in' button shown though check-in is only allowed on the date	Still reproduces	**Still reproduces**	Groomer > Upcoming still shows "Early check-in" on future bookings: #244 NORMAL Thu, Dec 3, 2026 10:00 AM – 11:00 AM / #243 NORMAL Wed, Dec 2, 2026 10:00 AM – 11:00 AM
UI-12	Low	Admin	Store selector overflows mobile screens	Still reproduces	**Still reproduces**	Admin dashboard at 375 px: document 694 px wide; store selector "QA Auto Store Edited — QAA-…" cut off (screenshot)
UI-13	Low	Admin	Cancellation-window field has no max/step; raw field name in error	Still reproduces	**Partially fixed**	New store form now shows hint '0–168 hours before…', but the input still has no max (min 0, step any); API with 200 → 400 'cancellationThresholdHours must be less than or equal to 168' (raw field name)
UI-14	Low	Admin	Technical/internal text shown to admins	Still reproduces	**Still reproduces**	Service master: 'Store services in service_master…', 'Database tenant scope (this list)', '3 service row(s) in DB with this storeId.'; Package master: 'package_master + package_info (serviceId)', 'package_info.packageId → service_master.id'; Forecast: '…in a later release.'
PERF-01	Medium	Customer	Slot availability saturates at ~45 requests/s	Inconclusive	**Inconclusive**	Single-user availability p50 384 ms. From the test browser throughput is still capped at ~3 req/s for every endpoint (availability 10 VU: 2.7 rps, p50 3.66 s; public /api/breeds 10 VU: 3.2 rps; 0 errors), so server capacity cannot be measured from here - needs k6/JMeter from a server
PERF-02	Medium	All	Every page requests each API twice	Partially fixed	**Partially fixed**	Admin dashboard load (index-C63CMm-c): 12 XHRs, all once except /api/common/dashboard ×2

Bug ID	Sev	Role	Title	Round 1	Round 2	Observed on build index-C63CMm-c (evidence)
PERF-03	Low	All	Single 1 MB bundle for all three portals	Still reproduces	**Still reproduces**	Single bundle index-C63CMm-c.js = 1,029 KB for all three portals

Test data and housekeeping

Test-only changes were reverted: the QAA-001 pet-size tiers were restored after FUN-10, the store created for FUN-18 (id 45) and the content item created for FUN-11 (id 5) were deleted, the service renamed for UI-05 was renamed back, and booking #252 (FUN-13) was declined. The QA customer password is now **Qa@Cust2029** (changed by the SEC-08 reset test). Note: the legacy 7-minute service 'QA OddDur' can no longer be edited because the new 10-minute minimum duration applies on save.

Screenshot evidence

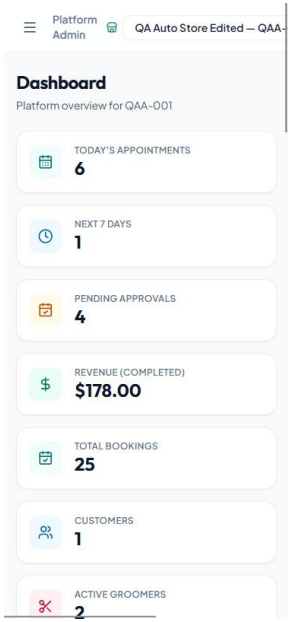


Fig. 1 - Admin dashboard at 375 px on build index-C63CMm-c: store selector cut off (UI-12 still reproduces); revenue now $178.00, matching the report (DB-01 fixed)

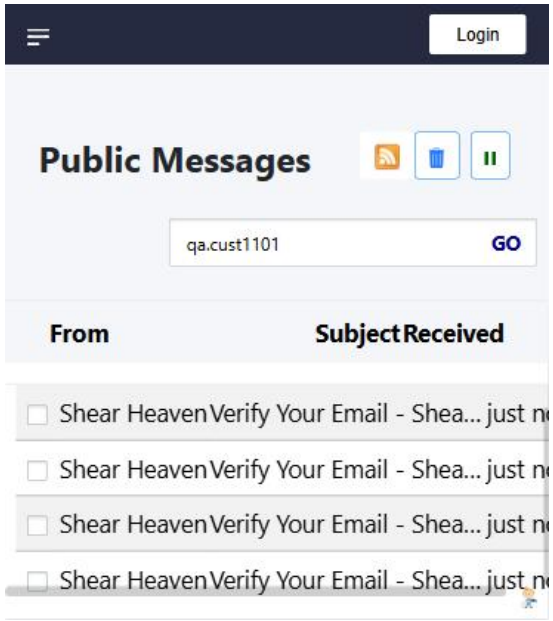


Fig. 2 - Password-reset emails still arrive titled 'Verify Your Email' (FUN-22 partially fixed)